

INT245: PENETRATION TESTING

L:2 T:0 P:2 Credits:3

Course Outcomes: Through this course students should be able to

CO1 :: Understand rules of engagement safely conducting the penetration testing exercise within an organization

CO2 :: Identify various footprinting techniques to enumerate a target

CO3 :: Apply a vulnerability scan strategy to detect, analyze and craft network traffic

CO4 :: Demonstrate and apply techniques for system hacking, exploit analysis, privilege escalation, and post-exploitation to gain, maintain, and automate controlled access to Windows and Linux systems

CO5 :: Analyze the cloud environments by identifying cloud attack surfaces, exploiting IAM privilege escalation paths, and enumerating exposed storage resources in AWS and Azure

CO6 :: Illustrate different testing deliverables out of penetration testing reports and suggest post corrective actions

Unit I

Planning and Scoping : Introduction to penetration testing concepts, types of penetration testing, phases of penetration testing, Organizational pentesting, compliance requirements, pentesting standards, environmental considerations, rules of engagement

Unit II

Footprinting and Gathering Intelligence : discover a target, gather essential data, website information gathering, Information gathering, types of information gathering, open source intelligence (OSINT)

Human and Physical Vulnerabilities : exploiting human psyche, physical attacks, Social engineering

Unit III

Vulnerability Scan : plan the vulnerability scan, scanning vulnerabilities, scanning tools, types of scans, detect defenses, analysing attack surface, crafting packets, network traffic analysis, evaluate wireless network traffic, analyzing scanning results, scanning logical vulnerabilities, analyze scanning results, evade detection and covering tracks, Scanning tools, types of scans

Preparing the Vulnerability Scan : Plan the Vulnerability Scan, Detect Defenses, Utilize Scanning Tools, Scanning logical vulnerabilities: - Scan identified targets, Evaluate Network traffic, Uncover Wireless Assets. Analyzing Scanning Results, Discover Nmap and NSE, Enumerate Network Hosts, Analyze output from scans

Unit IV

Web Application Exploitation : OWASP top 10 vulnerabilities, session hijacking, Crafting Request Forgery attacks, SQL injection, identifying SQLi vulnerabilities, cross-site scripting (XSS) attacks, exploiting browser

Mobile Device Exploitation : Deployment Models, identifying vulnerabilities, attacks on mobile devices, social engineering attacks, hacking Bluetooth signal, exploiting with malware

Unit V

XSS vulnerabilities identification : Identification of XSS vulnerabilities in the websites and the way they could be exploited

SQL Injection : Introduction to SQL injection, Automated SQL injection using SQLmap

Cloud Penetration Testing : Cloud Attack Surfaces (AWS/Azure), IAM Privilege Escalation, S3 Bucket Enumeration

Unit VI

Communication and Reporting : Communication path, communication triggers, reporting tools, identify report audience, report content, presentation of findings, define best practices for reports, recommending remediation, performing post-report delivery activities, Attacks on IoT devices

Active Directory Attacks : Kerberos Authentication Flaws, Kerberoasting, AS-REP Roasting, Domain Enumeration (BloodHound), Golden & Silver Ticket Attacks, Lateral Movement

List of Practicals / Experiments:

Gathering Information

- Gathering information using tools like theHarvester,
- Recon-ng
- Maltego
- shodan

Network discovery and security auditing

- Basic commands of Nmap
- Performing host and network scan using NSE scripts
- interpretation of gathered information using nmap

Vulnerability-Scanning

- Assessing system and network vulnerabilities using vulnerability scanners like
- Nmap,Nikto and Nessus

Metasploit

- Introduction to the tool
- basic commands for searching, selection, parameter configurations and deployment of exploits
- Exploitation of Windows XP and windows 7

Password Cracking

- exploiting vulnerabilities using password cracking tools like hashcat
- john the ripper
- cain and abel

Web Application Penetration Testing

- Evaluating web application security using tools like OWASP ZAP (Zed Attack Proxy)
- Burpe Suite

Cross-Site-Scripting(XSS)

- Introduction to cross site scripting, identification of websites vulnerable to cross site scripting

XSS vulnerabilities-identification

- Identification of XSS vulnerabilities in the websites and the way they could be exploited

XSS-Exploitation

- Exploitation of XSS vulnerabilities using javascript

SQL Injection(SQLi)

- Introduction to SQL injection, Automated SQL injection using SQLmap

Manual SQL Injection(SQLi)

- Demonstration of manual SQL injection attacks

References:

1. COMPTIA PENTEST+ STUDY GUIDE: EXAM PT0-002, 2ND EDITION by MIKE CHAPPLE, DAVID SEIDL, WILEY
2. PENETRATION _TESTING: A HANDS-ON INTRODUCTION TO HACKING by GEORGIA WEIDMAN, WILEY

